

VISBY BLUEPRINT — Master Checklist

THIS FILE IS KING. Fully read it at the start of every Claude Code session before doing anything else.

It is the single source of what to do next and in what order. Work top-to-bottom within the current phase.

A phase is done only when its **Gate** clears.

Update protocol: when Judah gives a new build command, ask: *"update blueprint.md with this?"*

Yes → update here AND memory.md. No → memory.md only. **Everything always goes to memory.md.**

Check items off here the moment they're done; evidence and detail go in memory.md.

Locked decisions (don't re-litigate): KYC = Civic (swap Persona) · card-present = Moov (Rainforest dropped) · shipping = EasyPost (direct UPS/FedEx/USPS adapters retired) · fee = 9% marketplace / 3.5% SDK, \$0.50 floor · bank linking = Stripe Financial Connections only (no Plaid/SnapTrade/pay-apps/brokerages) · Visby account = email + password + 2FA (seed phrases only when linking external wallets) · non-custodial always (Visby never holds funds) · burner card parked.

Phase 0 — Turn on what's already built

- 0.1 Run/verify all pending Supabase migrations (LAUNCH_CHECKLIST §1 + step_up/kyc/transfers stragglers) — Judah
- 0.2 Seed Judah's wallet as super_admin (admin_users INSERT) — Judah
- 0.3 Keys into env: CRON_SECRET, REVIEW_TOKEN_SECRET (fresh), EASYPOST_API_KEY (test EZTK), EMBEDDINGS_API_KEY; verify SENTRY_DSN + SECRET_ENCRYPTION_KEY in prod — Judah
- 0.4 Privy dashboard: enable Solana embedded wallets (fixes silent createWallet hang) — Judah
- 0.5 E2E-verify step-up MFA, then flip NEXT_PUBLIC_STEP_UP_ENFORCED=1 (KYC flag stays OFF until Phase 6)
- 0.6 Verify PWA state (manifest/service worker/icons) — reconcile conflicting records, finish if missing
- **Gate:** migrations confirmed on prod, admin login works, a new account gets a Solana wallet, step-up enforced live.

Phase 1 — Account & security backbone

- 1.1 Visby account layer: email + password + 2FA on the ACCOUNT (layered over Privy; not replacing wallet custody)
- 1.2 Seed-phrase UX only in the external-wallet linking flow (native embedded wallets never expose one)
- 1.3 Auth: /api/mint requires Privy token + callerOwnsWallet
- 1.4 Fix DM read IDOR (messages getThread/getConversations → authed context)
- 1.5 Fix upsertProfile IDOR (protectedProcedure + callerOwnsWallet)
- 1.6 /api/onramp/fulfill double-disburse idempotency lock
- 1.7 Transfers daily-cap TOCTOU → atomic DB RPC
- 1.8 Keyed/multi-source price feed (CoinGecko key + fallback)
- 1.9 Decide + wire step-up on charge-saved purchases (recommendation to Judah first)
- 1.10 Unique usernames (safe p2p send-by-handle)

- 1.11 Transfer confirm verifies amount (not just wallets present) + USDC transfers (spl-token)
- **Gate:** all listed routes reject unauth (401), password+2FA account flow works in preview, transfers hardened.

Phase 2 — Provenance completeness

- 2.1 QR code per item (serial → item URL), printable/downloadable; scan resolves physical item → on-chain record
- 2.2 Business bulk serial logging: CSV import → pending unminted records (business profiles only)
- 2.3 Mint-on-sale: order flow pulls the matching pending serial, mints its Tally, marks it live (shared order path)
- 2.4 Brand-verified badge UI on item page (data already persisted)
- 2.5 Counterfeit takedown flow: delist + seller suspension wired to flags/disputes/serial-flags + policy path
- 2.6 Provenance explainer surfaces (plain-English "what is a Tally?")
- **Gate:** a business bulk-logs serials that stay unminted until each sells; a QR on a physical item opens its provenance.

Phase 3 — Shipping & fulfillment (EasyPost)

- 3.1 EasyPost test key in; live-test full chain (ship-from → rate-shop → buy label → tracking/label_url → net payout)
- 3.2 Validate EasyPost SDK response-shape assumptions in src/lib/shipping.ts against the real API
- 3.3 Visby webhook receiver for EasyPost tracking → auto-confirm delivery → review email + payout release
- 3.4 Shipping insurance option at label purchase for high-value items
- 3.5 Retire direct UPS/FedEx/USPS adapters
- 3.6 Production billing: swap EasyPost account to Visby's fund account before live labels — Judah
- **Gate:** a test order ships with a real EasyPost test label and delivery webhook auto-fires review email + payout.

Phase 4 — Money rails completion (non-custodial always)

- 4.1 Stripe Financial Connections: bank link + verification; wallet-page bank tiles re-railed onto it
- 4.2 Remove Plaid + SnapTrade (code, tables, keys)
- 4.3 Fiat payouts: Stripe Connect transfer to seller bank when bank = Primary method
- 4.4 ACH pay-in
- 4.5 Multi-currency auto-conversion: seller receives their preferred currency on payout
- 4.6 Moov card reader wired into checkout (card-present → same order state machine → Tally mint + payout)
- 4.7 Order state machine: formal transition validator (legal-transition table + guards + unit tests)
- 4.8 Cross-provider reconciliation job: Stripe + Moov + on-chain vs 9%/3.5% fee math; alert on drift
- 4.9 Stripe Tax (marketplace facilitator) behind a flag — enable when Judah confirms nexus/entity
- 4.10 1099-K seller reporting via Stripe Connect, behind a flag
- **Gate:** money moves and settles across all rails without Visby taking custody; every rail reconciles.

Phase 5 — SDK & merchant experience

- 5.1 Merchant dashboard: orders/settlements list
- 5.2 Merchant dashboard: webhook delivery log + manual re-send

- 5.3 Merchant dashboard: revenue/fee breakdown
- 5.4 Extension: real Privy auth in popup
- 5.5 Extension-initiated partner checkout session
- 5.6 Merchant payout settlement wiring
- 5.7 SDK docs page: copy-paste quickstart polish
- **Gate:** a merchant can see every order, webhook, and dollar; extension completes a partner checkout end-to-end.

Phase 6 — Fraud & trust stack

- 6.1 Civic KYC: swap Persona implementation (keep webhook-canonical fail-closed architecture + same sell gates)
- 6.2 Fix multi-wallet KYC propagation (verify on one wallet unlocks the user's other selling wallets safely)
- 6.3 Flip `NEXT_PUBLIC_KYC_REQUIRED=1` (sell gated, buy open)
- 6.4 Chainalysis wallet screening before mint/sale/payout (fail-closed on sanctioned; admin review queue)
- 6.5 Dispute evidence capture: photo/doc upload + proof-of-delivery attach + admin evidence view
- 6.6 Chargeback playbook: evidence bundle export (delivery + provenance trail) per order
- 6.7 NFC chip workflow (tag write/verify → item page) — after QR proves the loop
- **Gate:** unverified users can buy but not sell; sanctioned wallets blocked; a dispute carries evidence an issuer would accept.

Phase 7 — UX & "toddler-proof" experience

- 7.1 First-run onboarding walkthrough (what Visby is, what a Tally is, how paying works — zero jargon)
- 7.2 Empty + error states sweep: every screen has a helpful next action
- 7.3 Offers flow: preset offer slider → real accept → checkout at offered price
- 7.4 Address book (saved shipping addresses)
- 7.5 Order-tracking timeline UX
- 7.6 Help center: FAQ + contact-support flow wired to order state machine (self-heal email triage, injection-guarded)
- 7.7 Self-serve returns/refund request flow (feeds disputes; refund reflects on Tally provenance)
- 7.8 Notification preferences center (email/push toggles)
- 7.9 Seller analytics (views, likes, conversion) on seller dashboard
- 7.10 SEO/sharing: OG images for items + profiles
- 7.11 Fee transparency: seller sees 9% + shipping math before listing; buyer always sees final total before confirming
- **Gate:** a first-time non-crypto user completes signup → browse → buy → track without help or jargon.

Phase 8 — Compliance & legal plumbing

- 8.1 CCPA/GDPR data-export endpoint
- 8.2 Account-deletion endpoint (wallet/provenance caveats explained plainly)
- 8.3 Seller/Marketplace Agreement + Acceptable Use routes (counsel supplies content; admin PDF-upload exists)

- 8.4 Company email aliases (Resend catch-all; needs Judah's domain DNS)
- 8.5 AML/KYC record-keeping hooks (screening results retained + exportable)
- **Gate:** a user can export or delete their data; all four legal routes live.

Phase 9 — Platform delivery

- 9.1 Capacitor iOS/Android: local build steps (Xcode/Android Studio, dev accounts, APNs/FCM) — Judah + Claude
- 9.2 Extension store-readiness (icons, listing, honesty popups verified)
- 9.3 PWA verified installable (manifest, SW, icons, Lighthouse ≥ 90)
- **Gate:** app runs on a real phone; extension loads from a packed build; PWA installs.

Phase 10 — DESIGN DEBUG & CLEANUP PREVIEW

- 10.1 Page-by-page sweep of every route against design.md (tokens only, type scale, S-grid, glass-nesting law, gradient budget, one focal point)
- 10.2 Light + dark parity audit
- 10.3 WCAG contrast measurements on worst-case translucent surfaces; reduced-motion/transparency honored
- 10.4 Kill visual drift: hardcoded colors, off-scale font sizes, emoji regressions, inconsistent radii
- 10.5 Before/after preview screenshots per page delivered to Judah; fix everything he flags
- **Gate:** Judah signs off on the screenshot review; zero design-rule violations remain.

Phase 11 — TEST EVERYTHING + mainnet launch

- 11.1 Unit: fee math (9%/3.5%/floor), state-machine transitions, step-up crypto, serial-registry verdicts
 - 11.2 Integration: Privy $\leftrightarrow$ Supabase, mint $\leftrightarrow$ Arweave $\leftrightarrow$ Helius read-back, Stripe/Moov/EasyPost/Civic webhooks, SDK settle
 - 11.3 E2E (Playwright): signup $\rightarrow$ wallet $\rightarrow$ mint+serial $\rightarrow$ list $\rightarrow$ buy (card & crypto) $\rightarrow$ ship $\rightarrow$ deliver $\rightarrow$ review $\rightarrow$ payout; SDK merchant journey; dispute/refund journey
 - 11.4 Unhappy paths: RPC failure mid-action, double-submit, wrong wallet, insufficient funds, concurrent actions, canceled signing
 - 11.5 Load: drop-spike on mint + checkout; Helius/Vercel/Supabase limits; cache hot reads
 - 11.6 Security: threat-model review, dependency audit, external pentest prep, bug-bounty scoping
 - 11.7 Staging (devnet + test keys) full regression
 - 11.8 Mainnet closed beta: allowlisted, tiny real value, non-custodial verified with real money
 - 11.9 Devnet $\rightarrow$ mainnet cutover: fund monitored mint wallet, pre-fund Arweave, live keys, explorer links
 - 11.10 Multi-crypto mainnet enable: re-run `scripts/verify-payable-tokens.mjs`, wire Li.Fi `execute()` swap-pay, flip `NEXT_PUBLIC_MULTICRYPTO_ENABLED=1`
 - 11.11 Launch-day smoke on mainnet: mint $\rightarrow$ serial $\rightarrow$ list $\rightarrow$ buy $\rightarrow$ confirm with a tiny real tx
 - **Gate:** zero open S0/S1 bugs, one full lifecycle completed by a real buyer with real money, mainnet live.
-

PARKED — do NOT build now

- Burner card (Lithic, regulated, PCI-scoped) — explicitly low priority, after core platform
- Novo business banking — custody-directive flag; needs attorney sign-off
- Coinbase Commerce — confirm with Judah before building (native SOL/USDC + Li.Fi may cover it)
- Basis Theory card vault — only at ~10k+ card sales/mo
- KMS mint-authority custody — revisit at Phase 11 (mainnet timeline)